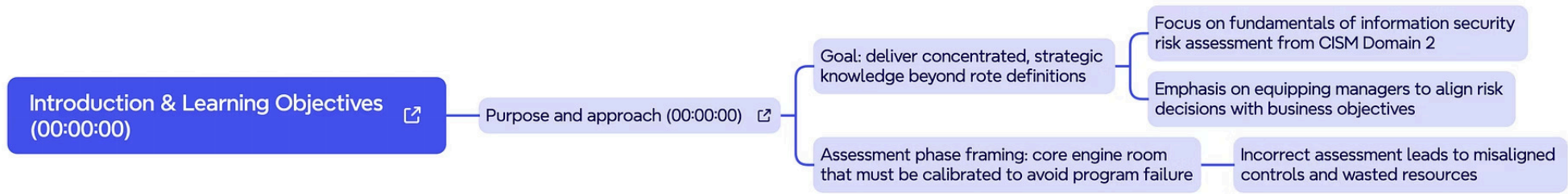




NCyTE CISM Course

Domain 2 – Information Risk Management, Part 1

A focused exploration of the foundational concepts, frameworks, and practices that underpin effective information security risk management — aligned with the CISM exam body of knowledge.



Introduction & Learning Objectives

DOMAIN 2 OVERVIEW

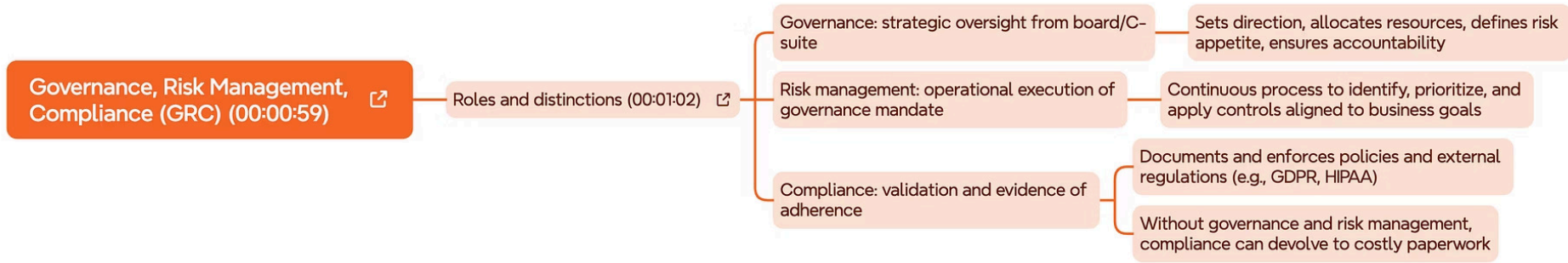
This module delivers **concentrated, strategic knowledge** of information security risk assessment drawn directly from CISM Domain 2. Rather than simply defining terms, the goal is to build the reasoning and judgment needed to apply these concepts on the exam and in the field.

Purpose & Approach

- Go beyond definitions to applied understanding
- Emphasize aligning risk decisions with business objectives
- Frame assessment as a core engine room for program success

Key Exam Mindset

- Incorrect assessment leads to misaligned controls and wasted resources
- Risk decisions must support — not conflict with — business goals
- Focus on fundamentals that CISM buyers rely on daily



Governance, Risk Management & Compliance (GRC)

00:00:59

GRC is not a monolithic function — it is a triad of related but distinct disciplines. Understanding how these roles interact is essential for CISM candidates, as each carries separate responsibilities and accountability structures.

Governance

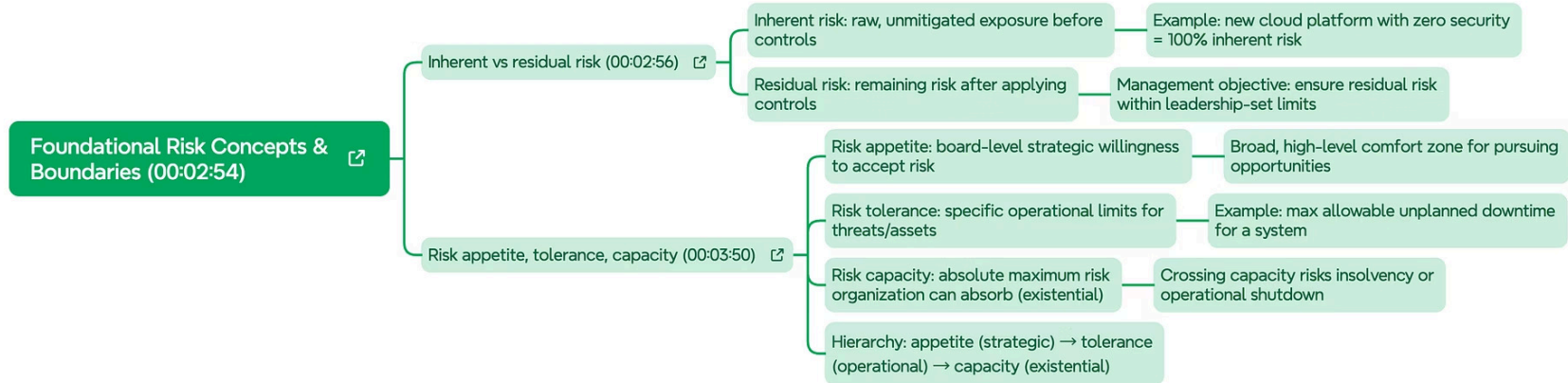
Strategic oversight from the board and C-suite. Sets direction, allocates resources, defines risk appetite, and ensures accountability across the organization.

Risk Management

Operational execution of the governance mandate. A continuous process to identify, prioritize, and apply controls aligned to business goals.

Compliance

Validation and evidence of adherence. Documents and enforces policies and external regulations (e.g., GDPR, HIPAA). Without governance, compliance becomes costly paperwork.



Foundational Risk Concepts & Boundaries

00:02:54

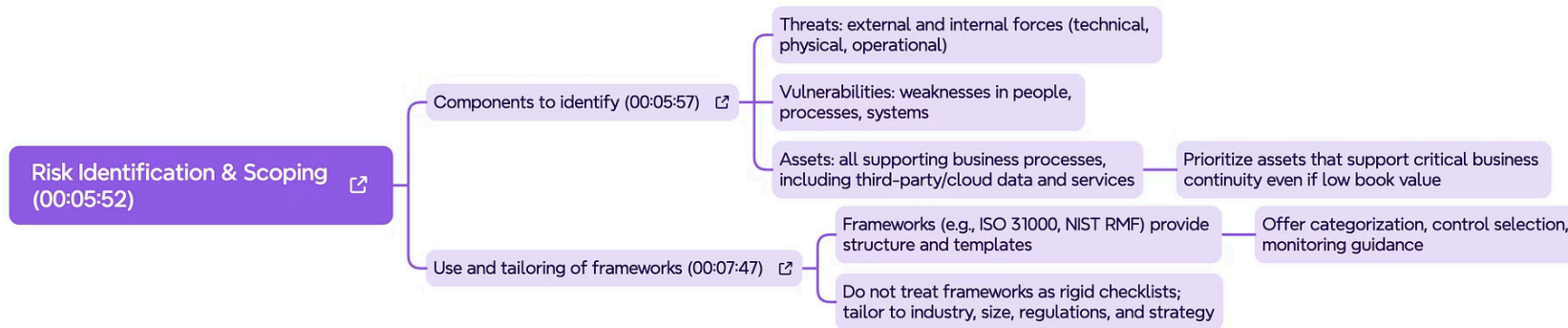
CISM candidates must clearly distinguish between key risk terms. These concepts form the vocabulary of risk decision-making and appear frequently on the exam.

Inherent vs. Residual Risk

Inherent risk is the raw, unmitigated exposure before any controls are applied — e.g., a new cloud platform with zero security is 100% inherent risk. **Residual risk** is what remains after controls; the management objective is to ensure residual risk stays within leadership-set limits.

Risk Appetite, Tolerance & Capacity

Appetite: the board-level strategic willingness to accept risk — a broad, high-level comfort zone for pursuing opportunities. **Tolerance:** specific operational limits for threats and assets — e.g., max allowable unplanned downtime for a system. **Capacity:** the absolute maximum risk the organization can absorb (existential). Hierarchy: appetite (strategic) → tolerance (operational) → capacity (existential).



Risk Identification & Scoping

00:05:52

Effective risk identification requires a structured, asset-centric approach that considers both external and internal threat sources, and is guided — but not constrained — by established frameworks.

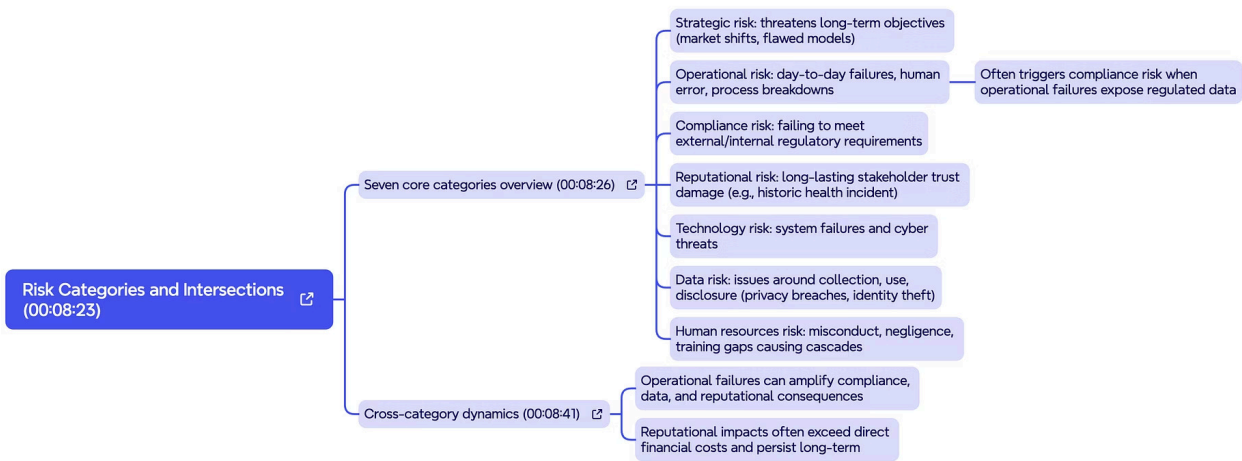
What to Identify

- **Threats:** External and internal forces — technical, physical, and operational
- **Vulnerabilities:** Weaknesses in people, processes, and systems
- **Assets:** All supporting business processes, including third-party/cloud data and services — prioritize assets supporting critical business continuity even if low book value

Using Frameworks Effectively

Frameworks such as **ISO 31000**, **NIST RMF**, and others provide structure and templates — but must be tailored to the industry, size, and regulatory context of the organization.

- Do not treat frameworks as rigid checklists. Offer categorization, control selection, and monitoring guidance instead.



Risk Categories & Intersections

00:08:23

Risk does not exist in isolation. CISM candidates must recognize that risk categories often intersect and amplify one another — understanding these cross-category dynamics is critical for effective risk management.



Strategic Risk

Threatens long-term objectives through market shifts or flawed business models. Demands board-level attention.



Reputational Risk

Long-lasting stakeholder trust damage (e.g., data breach incident). Reputational impacts often exceed direct financial costs and persist long-term.



Human Resources Risk

Misconduct, negligence, and training gaps causing cascading failures across security programs.



Operational Risk

Day-to-day failures from human error and process breakdowns. Often triggers compliance risk when failures expose regulated data.



Technology Risk

System failures and cyber threats. Operational failures can amplify compliance, data, and reputational risks simultaneously.



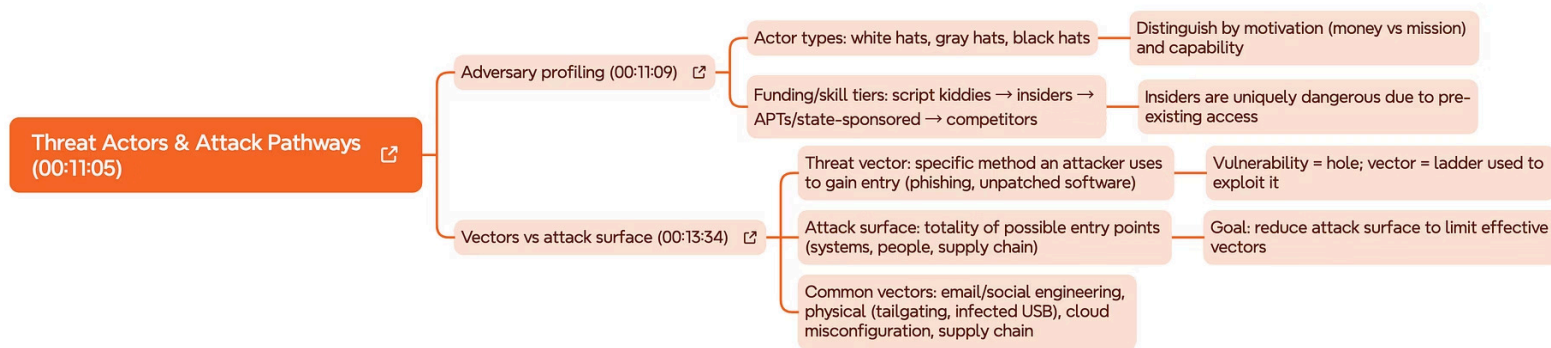
Compliance Risk

Failing to meet external/internal regulatory requirements. Penalties, fines, and audit findings result from gaps.



Data Risk

Issues around data collection, use, and disclosure — including privacy breaches and identity theft.



Threat Actors & Attack Pathways

00:11:05

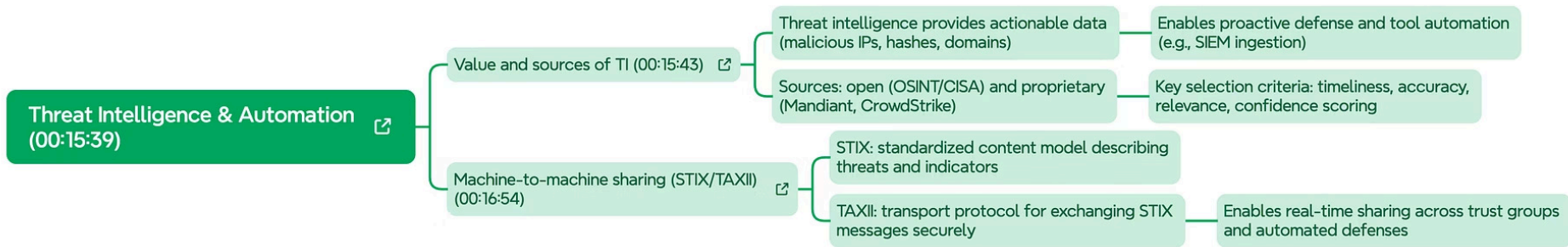
Knowing *who* attacks and *how* they gain access is foundational to risk assessment. CISM professionals must profile adversaries and map attack surfaces to prioritize defenses effectively.

Adversary Profiling

- **Actor types:** White hats, gray hats, black hats — distinguished by motivation (money vs. mission) and capability
- **Funding tiers:** Script kiddies → insiders → APT/state-sponsored → competitors
- Insiders are uniquely dangerous due to pre-existing access

Vectors vs. Attack Surface

- **Vector:** The specific method an actor uses to gain entry (e.g., phishing, unpatched software)
- **Vulnerability** = hole; **vector** = ladder used to exploit it
- **Attack surface:** The totality of possible entry points — systems, people, and supply chain
- Goal: Reduce attack surface to limit effective vectors
- Common vectors: Email/social engineering, physical tailgating, infected USB, cloud misconfiguration



Threat Intelligence & Automation

00:15:39

Threat intelligence transforms raw data into actionable security decisions. When combined with automation, it enables organizations to detect and respond to threats at machine speed.

Value of Threat Intelligence

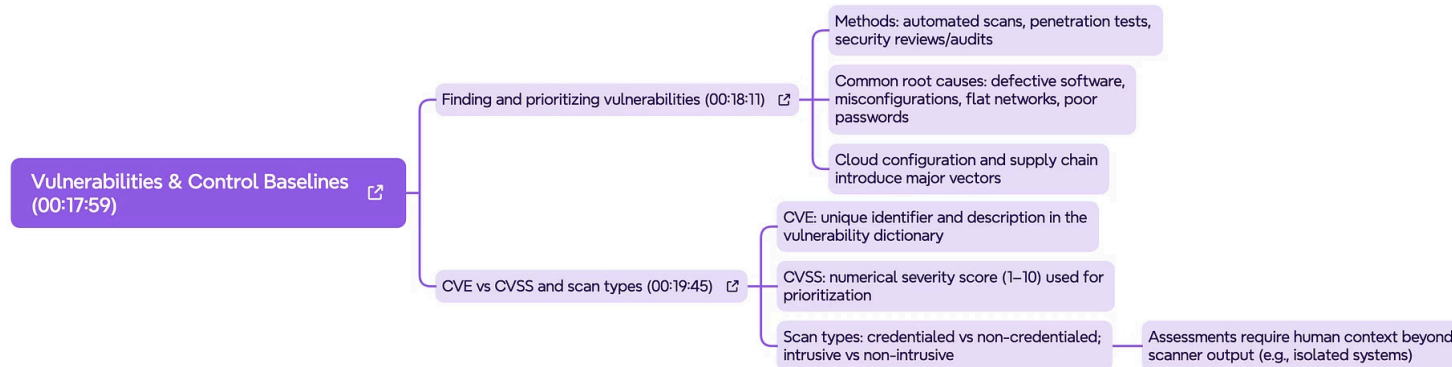
Actionable data — including malicious IPs, hashes, and domains — enables proactive defense and automation of tool feeds (e.g., SIEM integrations). Key selection criteria: timeliness, accuracy, relevance, and confidence scoring.

Sources: Open & Proprietary

Open sources include **CISA, CIRT, and FS-ISAC**. Proprietary sources (e.g., Mandiant, CrowdStrike) provide deeper context and curated threat feeds for enterprise use.

STIX/TAXII Standards

STIX: A standardized content model for describing threats and indicators. **TAXII**: The transport protocol for exchanging STIX messages securely — enabling real-time sharing across trust groups and automated defenses.



Vulnerabilities & Control Baselines

00:17:59

Vulnerability management requires both discovery and context. Understanding how to find, classify, and score vulnerabilities — and how to evaluate them against control baselines — is a core CISM skill.

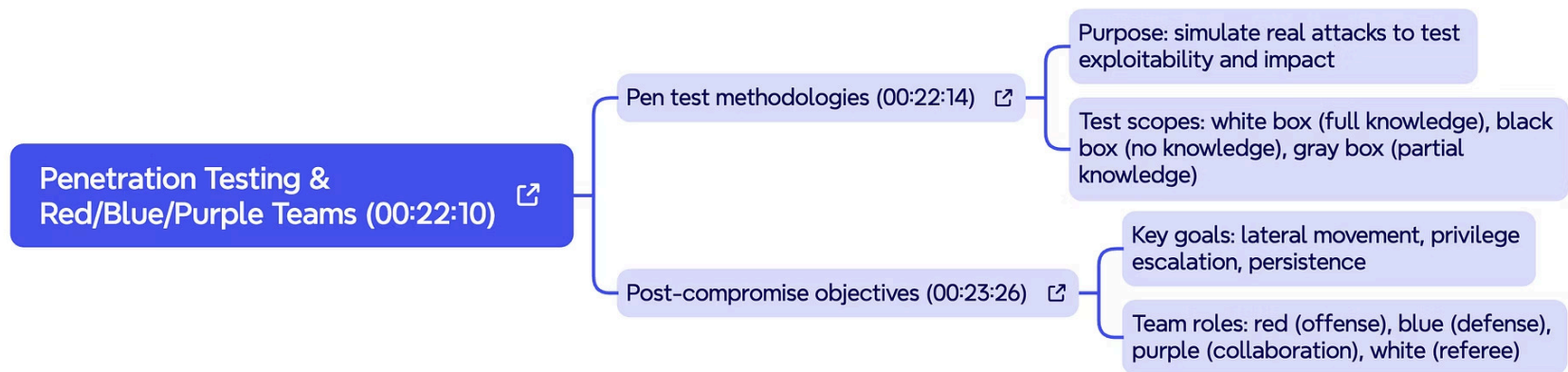
Finding & Prioritizing Vulnerabilities

- **Methods:** Automated scans, penetration tests, security reviews, and audits
- **Common root causes:** Defective software, misconfigurations, flat networks, poor password hygiene
- Cloud configuration and supply chain introduce major vectors

CVE, CVSS & Scan Types

- **CVE:** Common Vulnerability and Exposures — unique identifier and description in the vulnerability dictionary
- **CVSS:** Common Vulnerability Scoring System — numeric severity score (1–10) used for prioritization
- **Scan types:** Credentialed (intrusive) vs. non-credentialed (non-intrusive)

⚠ Assessments require human context beyond scanner output — e.g., isolated systems may score high but pose lower operational risk.



Penetration Testing & Red/Blue/Purple Teams

00:22:10

Penetration testing simulates real adversarial attacks to validate whether vulnerabilities are truly exploitable — and to measure the actual business impact of a successful compromise.

1

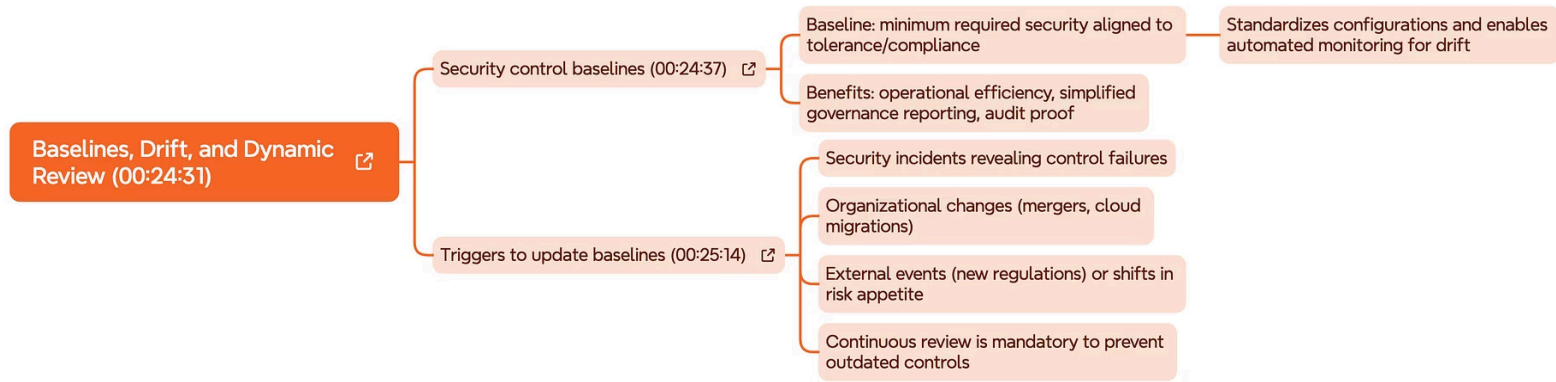
Pen Test Methodologies

- **Purpose:** Simulate real attacks to test exploitability and impact — not just surface scanning
- **White box:** Full knowledge of the environment; **Black box:** No prior knowledge; **Gray box:** Partial knowledge

2

Post-Compromise Objectives

- **Key goals:** Lateral movement, privilege escalation, and persistence — measuring how far an attacker can go
- **Red team:** Offense; **Blue team:** Defense; **Purple team:** Collaboration to share findings in real time; **White team:** Referee and rules of engagement



Baselines, Drift, and Dynamic Review

00:24:31

Security control baselines define the minimum required security posture aligned to an organization's tolerance and compliance requirements. But baselines are not static — they must be actively maintained to remain effective.

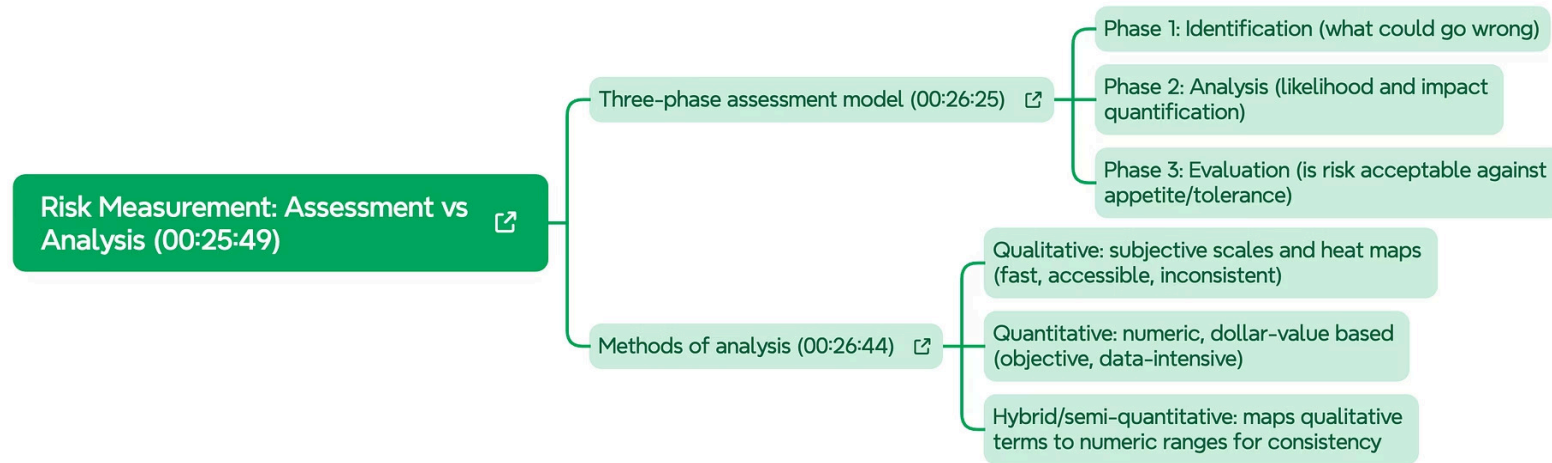
Security Control Baselines

- Minimum required security aligned to tolerance and compliance
- Standardizes configurations and enables automated monitoring for drift
- **Benefits:** Operational efficiency, simplified governance reporting, and audit proof

Triggers to Update Baselines

- Security incidents revealing control failures
- Organizational changes — mergers, cloud migrations, new business lines
- External events: new regulations, shifts in risk appetite

- ❑ Continuous review is mandatory to prevent outdated controls from creating false confidence.



Risk Assessment Methodologies

DOMAIN 2 – DEEP DIVE

Risk assessment is the structured process of identifying, analyzing, and evaluating risk to determine appropriate treatment. CISM candidates must understand both qualitative and quantitative approaches and when to apply each.

Qualitative Assessment

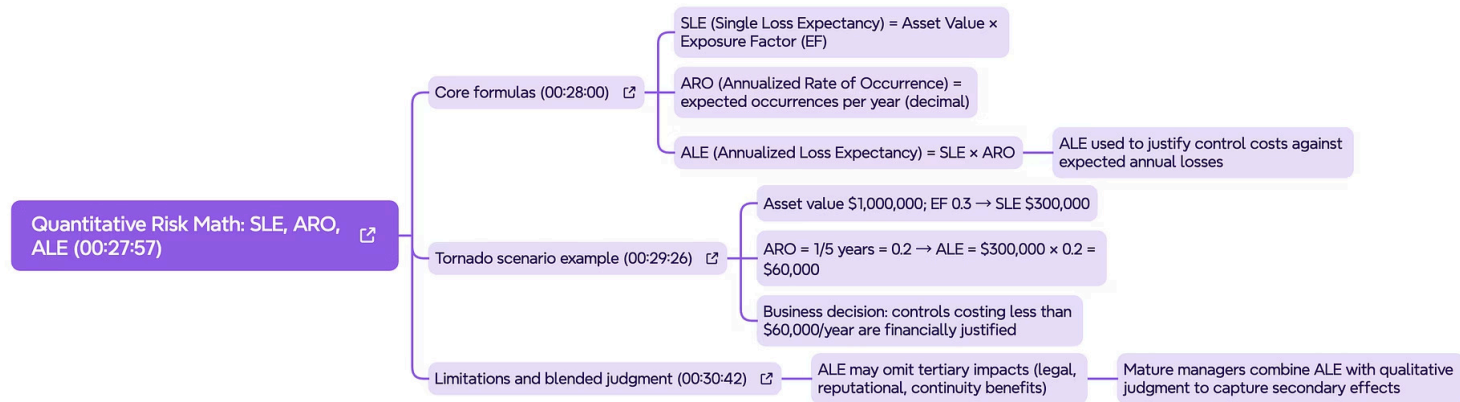
Uses descriptive scales (High / Medium / Low) based on expert judgment. Faster to conduct, ideal when numerical data is unavailable. Commonly used in initial risk screening and executive reporting.

Quantitative Assessment

Assigns numeric values to risk — including **ALE (Annualized Loss Expectancy) = $SLE \times ARO$** . Enables cost-benefit analysis of controls. Requires reliable historical data and actuarial inputs.

Semi-Quantitative Hybrid

Combines both approaches: uses ranked scales (1–5) mapped to financial impact ranges. Balances rigor with practicality for most enterprise environments. Widely used in CISM exam scenarios.



Risk Treatment & Response Options

DOMAIN 2 – RISK RESPONSE

Once risks are assessed, organizations must decide how to respond. CISM candidates must be fluent in all four risk treatment options and understand the business context that drives each decision.



Risk Mitigation

Implement controls to reduce the likelihood or impact of a risk to an acceptable level. The most common treatment approach in security programs.



Risk Transfer

Shift the financial burden to a third party — e.g., cyber insurance or outsourcing to an MSSP. Does not eliminate the risk, only the financial exposure.



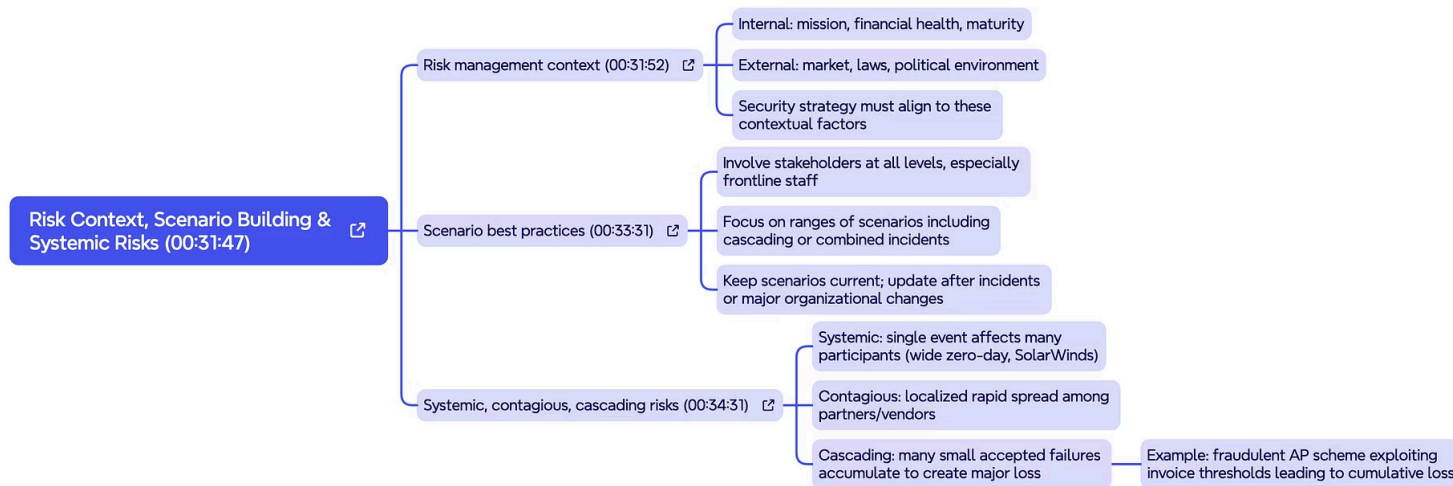
Risk Avoidance

Discontinue the activity that creates the risk. Appropriate when risk exceeds tolerance and no cost-effective controls exist — e.g., exiting a high-risk market.



Risk Acceptance

Formally acknowledge and accept residual risk when it falls within risk appetite. Must be documented and approved by appropriate authority — never informal.



Domain 2 – Part 1 Key Takeaways

EXAM PREP SUMMARY

Review these core principles before your CISM exam. Each concept maps directly to exam questions that test your ability to make sound, business-aligned risk decisions — not just recall definitions.

1 GRC roles are distinct but interdependent

Governance sets direction, risk management executes, and compliance validates. Confusing these roles leads to accountability gaps.

2 Risk vocabulary must be precise

Inherent vs. residual risk, and the hierarchy of appetite → tolerance → capacity are high-frequency exam topics requiring clear differentiation.

3 Risk categories intersect and amplify

Operational failures create compliance exposure; reputational damage persists longer than financial loss. Think in systems, not silos.

4 Threat intelligence and baselines require continuous upkeep

Static controls and outdated threat feeds create false confidence. CISM professionals champion dynamic, evidence-based risk management programs.